

Política de Seguridad y Control de Accesos de Helios

Nordia Bank · Dirección de Seguridad de la Información

Versión del documento: 2.7 · Clasificación: Interno restringido · Vigente desde: 1 de febrero de 2026

Aprobada por: Comité de Seguridad de la Información (CSI)

1. Ámbito de aplicación

Esta política aplica a todos los accesos a la plataforma Helios, sus servicios (Kestrel, Vela, Aria, Halo) y los datos almacenados en cualquiera de sus zonas. Es de obligado cumplimiento para empleados, personal de empresas proveedoras y procesos automatizados.

El incumplimiento de esta política se considera falta grave según el régimen disciplinario interno y puede conllevar la revocación inmediata de accesos.

2. Modelo de roles

El control de acceso es basado en roles (RBAC), federado contra Okta. No se admiten usuarios locales en ningún servicio de la plataforma.

Rol	Lectura curated	Escritura curated	Acceso a PII	Gestión de DAG	Administración
helios-reader	Sí	No	No	No	No
helios-analyst	Sí	No	Solo seudonimizada	No	No
helios-engineer	Sí	Sí	Solo seudonimizada	Sí	No
helios-operator	Sí	Sí	No	Sí	Parcial
helios-admin	Sí	Sí	Sí, con registro	Sí	Sí
helios-audit	Sí	No	Metadatos únicamente	No	No

El rol helios-admin está limitado a un máximo de 5 personas simultáneas en toda la organización. La lista nominal se revisa trimestralmente por el CSI.

3. Gestión de credenciales

Las credenciales de servicio se rotan automáticamente cada 90 días mediante AWS Secrets Manager. Las credenciales de usuario humano no existen como tales: el acceso se realiza siempre mediante SSO con token de sesión de duración máxima de 8 horas.

Está prohibido almacenar credenciales, tokens o claves en código fuente, ficheros de configuración versionados, cuadernos de análisis o mensajes de chat corporativo. Los repositorios se escanean diariamente con detección de secretos y cualquier hallazgo genera una incidencia de severidad P2 con revocación automática del secreto detectado.

La autenticación multifactor es obligatoria para todos los roles con capacidad de escritura. Para helios-admin se exige además llave física FIDO2; la MFA basada en SMS no se acepta en ningún caso.

4. Clasificación de datos

Nivel	Descripción	Ejemplos	Cifrado en reposo	Exportable
C0 — Público	Sin restricción	Tipos de cambio publicados	Estándar	Sí
C1 — Interno	Uso interno general	Catálogos de producto	AES-256	Con aprobación

Nivel	Descripción	Ejemplos	Cifrado en reposo	Exportable
C2 — Confidencial	Datos de negocio sensibles	Márgenes, modelos de scoring	AES-256 + KMS dedicada	No
C3 — Personal	Datos de carácter personal	DNI, IBAN, dirección	AES-256 + KMS dedicada	No
C4 — Crítico	Categorías especiales y credenciales	Datos de salud, claves	AES-256 + HSM	Nunca

Todo conjunto de datos debe estar clasificado antes de su primera carga en la zona *curated*. Un dataset sin clasificación se bloquea automáticamente y no puede ser consultado por ningún rol distinto de `helios-operator`.

5. Tratamiento de datos personales

El tratamiento de datos personales se rige por el RGPD y por la política corporativa de privacidad NOR-PRIV-03. Los principios operativos aplicables en Helios son:

Minimización. Ningún pipeline puede propagar campos personales a la zona *serving* si no existe una finalidad documentada en el registro de actividades de tratamiento.

Seudonimización por defecto. Los identificadores directos se sustituyen por tokens irreversibles generados por el servicio Trama. La re-identificación requiere un rol específico (`trama-reidentify`) y deja registro de auditoría inmutable.

Derecho de supresión. Las solicitudes de borrado se ejecutan mediante el proceso `gdpr-erasure` y deben completarse en un plazo máximo de 30 días naturales desde la recepción de la solicitud. El proceso alcanza a las zonas *curated*, *serving* y *archive*; la zona *raw* queda cubierta por su propia caducidad de 30 días.

Transferencias internacionales. No se permite el procesamiento de datos de nivel C3 o C4 fuera del Espacio Económico Europeo. Esta restricción aplica también a servicios de inteligencia artificial: solo pueden usarse modelos alojados en regiones europeas a través de la pasarela Lumen.

6. Registro y auditoría

Todos los accesos a datos de nivel C2 o superior se registran en el log de auditoría inmutable, almacenado en una cuenta AWS separada con bloqueo de objetos (*object lock*) activado.

El periodo de conservación de los logs de auditoría es de 400 días. Este valor responde al requisito supervisor de disponer de trazabilidad completa del ejercicio natural anterior más el corriente. Los logs no pueden eliminarse ni modificarse antes de ese plazo, ni siquiera por el rol `helios-admin`.

Las consultas al log de auditoría requieren el rol `helios-audit` y quedan a su vez registradas.

7. Uso de inteligencia artificial sobre datos de Helios

El uso de modelos de lenguaje sobre datos de la plataforma está permitido bajo tres condiciones acumulativas: acceso exclusivamente a través de la pasarela Lumen, prohibición absoluta de enviar datos de nivel C3 o C4 en los prompts salvo seudonimización previa, y registro del propósito del tratamiento en el catálogo de casos de uso de IA.

Los sistemas de recuperación aumentada (RAG) contruidos sobre documentación o datos de Helios deben heredar los permisos del usuario que consulta. Está expresamente prohibido construir un índice único consultable por todos los usuarios si dicho índice contiene documentos con niveles de acceso heterogéneos. La comprobación de permisos debe realizarse en el momento de la recuperación, no únicamente en la capa de presentación.

8. Revisión de accesos

Los accesos se recertifican semestralmente. El responsable de cada equipo debe confirmar la vigencia de los permisos de sus miembros. Los accesos no recertificados en un plazo de 15 días desde la solicitud se revocan automáticamente.

Las cuentas de servicio se revisan anualmente y deben tener siempre una persona responsable identificada. Una cuenta de servicio sin responsable identificado se deshabilita.